

# Enterprise IT Ticketing System Lab — Zammad + Postfix + Dovecot

*A production-realistic homelab simulating how IT/Sysadmin teams in German companies manage helpdesk operations using open-source tools.*



# Table of Contents

- [Overview](#)
  - [Architecture](#)
  - [Skills Demonstrated](#)
  - [Repository Structure](#)
  - [Lab Phases](#)
    - [Phase 1 — Setup & Email Integration](#)
    - [Phase 2 — Agents, Groups & Permissions](#)
    - [Phase 3 — Automation, SLAs & Triggers](#)
    - [Phase 4 — REST API Integration & Monitoring](#)
    - [Phase 5 — Security Hardening & Backup](#)
  - [Live IT Administration](#)
  - [IT Governance, Risk & Compliance](#)
  - [Threat Modelling — STRIDE + LINDDUN](#)
  - [Cyber Resilience](#)
  - [How to Reproduce This Lab](#)
  - [Scripts Reference](#)
- 

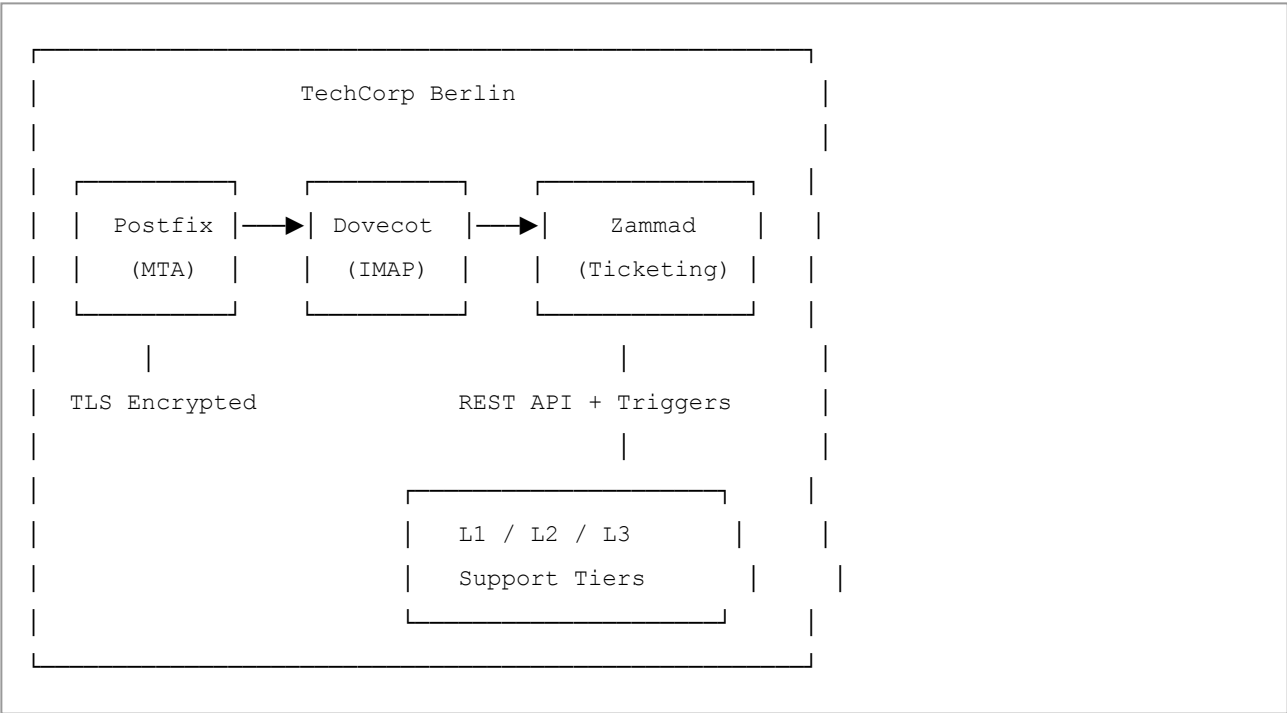
## Overview

This lab replicates the day-to-day IT operations of a mid-sized German company — **TechCorp Berlin** — using entirely open-source tools. It covers the full stack: mail server configuration, ticket automation, SLA enforcement, REST API integration, security hardening, and live IT administration.

Built, configured, and operated end-to-end as a hands-on demonstration of real-world IT/Sysadmin skills, aligned with German enterprise standards including **ITIL v4**, **DSGVO (GDPR)**, and **BSI Grundschutz**.

---

## Architecture



# Skills Demonstrated

| Domain                          | Skills                                                                               |
|---------------------------------|--------------------------------------------------------------------------------------|
| Mail Server Administration      | Postfix MTA, Dovecot IMAP, virtual mailboxes, mail routing, TLS encryption           |
| ITSM / ITIL v4                  | L1/L2/L3 support tiers, SLA configuration, escalation management, incident lifecycle |
| Ticketing System Administration | Zammad setup, group/agent management, trigger automation, scheduler jobs             |
| REST API Integration            | Token-based auth, programmatic ticket creation, SLA breach monitoring via API        |
| Security Hardening              | TLS for SMTP/IMAP, Fail2ban brute-force protection, DSGVO-compliant data retention   |
| Automation & Scripting          | Bash scripts for monitoring, backup, and retention; cron scheduling                  |
| IT Governance                   | ITIL v4 service management, change management, continual improvement                 |
| Risk Assessment                 | Risk register, likelihood/impact analysis, mitigation controls                       |
| Compliance                      | DSGVO/GDPR, BSI Grundschutz baseline controls, audit trail management                |
| Threat Modelling                | STRIDE per component, LINDDUN for personal data flows — 37 threats identified        |
| Cyber Resilience                | NIST CSF alignment across all five functions; RTO/RPO defined                        |

# Repository Structure

```
enterprise-it-ticketing-lab/
├─ README.md
├─ scripts/
│   ├─ morning-check.sh          # Daily system health check
│   ├─ zammad-monitor.sh        # SLA breach monitoring via API
│   ├─ zammad-backup.sh         # DSGVO-compliant backup script
│   └─ zammad-retention.sh       # 90-day data retention policy
├─ config/
│   ├─ postfix/                 # Postfix virtual mailbox config
│   ├─ dovecot/                 # Dovecot IMAP + TLS config
│   └─ fail2ban/                # Fail2ban jail configuration
└─ screenshots/                 # Lab evidence screenshots
```

# Lab Phases

## Phase 1 — Setup & Email Integration

Configured a complete mail stack from scratch on Ubuntu 22.04. Postfix was set up as the MTA with virtual mailbox support for `techcorp-berlin.de`. Dovecot was configured for IMAP authentication using a `passwd-file` backend, delivering mail to `/var/mail/vhosts/`. Zammad was then connected to the helpdesk IMAP mailbox, verified end-to-end email flow using `swaks`, and confirmed ticket creation from inbound email.

### Key configuration fixes applied:

| Item                                        | Resolution                                                        |
|---------------------------------------------|-------------------------------------------------------------------|
| Postfix <code>mydestination</code> conflict | Removed domain from <code>mydestination</code> , moved to virtual |
| Postfix <code>virtual_mailbox_limit</code>  | Set to <code>0</code> to allow unrestricted mailbox size          |
| Dovecot system auth                         | Disabled in favour of <code>passwd-file</code> auth               |
| Dovecot userdb                              | Configured as static <code>vmail</code> delivery                  |
| Zammad IMAP auth                            | Fixed username format to full email address                       |
| Stuck mail queue                            | Cleared using <code>postsuper -d ALL deferred</code>              |

## Phase 2 — Agents, Groups & Permissions

Built the complete L1/L2/L3 support structure inside Zammad, reflecting how German IT departments are typically organised.

### Support Structure:

#### TechCorp Berlin IT Support

|                  |                      |                                   |
|------------------|----------------------|-----------------------------------|
| └─ L1-Helpdesk   | → Agent: Anna Müller | (First contact, general issues)   |
| └─ L2-IT-Support | → Agent: Ben Schmidt | (Escalated technical issues)      |
| └─ L3-Sysadmin   | → Agent: Clara Weber | (Infrastructure, critical issues) |

Agents were created programmatically via the Zammad Rails runner and assigned full group access. Auto-routing triggers were configured to direct incoming tickets to the correct tier based on subject keywords.

#### Auto-Routing Logic:

| Keyword in Subject         | Routes To     |
|----------------------------|---------------|
| VPN, network               | L2-IT-Support |
| critical, database, backup | L3-Sysadmin   |
| Everything else            | L1-Helpdesk   |



Groups Panel

Groups management panel showing the TechCorp Berlin organisational structure

## Phase 3 — Automation, SLAs & Triggers

Configured ITIL v4-aligned SLAs with escalation timers per support tier, enforced automatically by Zammad on every incoming ticket.

#### SLA Configuration:

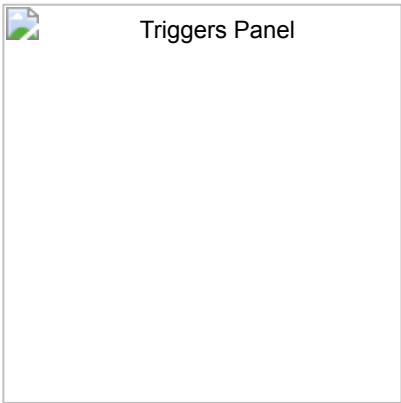
| Tier          | First Response | Solution Time |
|---------------|----------------|---------------|
| L1-Helpdesk   | 1 hour         | 8 hours       |
| L2-IT-Support | 2 hours        | 24 hours      |
| L3-Sysadmin   | 4 hours        | 72 hours      |



Three-tier SLA configuration with ITIL-aligned escalation times per group

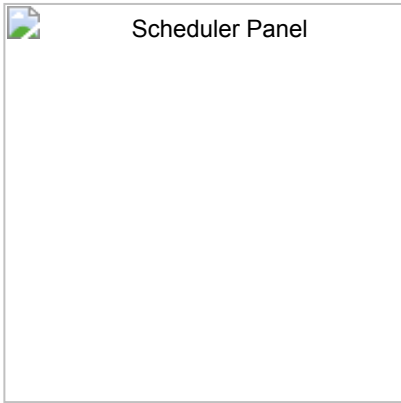
Automation Triggers:

| Trigger                        | Function                                                |
|--------------------------------|---------------------------------------------------------|
| Auto-Reply-On-Ticket-Open      | Sends confirmation email to customer on ticket creation |
| Escalate-L1-to-L2-Notification | Notifies L2 and reassigns when L1 SLA is breached       |
| Route-to-L1/L2/L3              | Auto-routes tickets by keyword matching                 |
| Tag-VPN-Tickets                | Tags VPN tickets for reporting                          |
| Tag-Database-Tickets           | Tags database tickets for reporting                     |



Full automation trigger suite — routing, escalation, tagging, and customer notification

An **Auto-close Scheduler** was also configured to automatically close tickets with no customer response after 48 hours, running daily at 08:00.



Scheduled job for automatic ticket closure after 48 hours of inactivity

## Phase 4 — REST API Integration & Monitoring

Authenticated to the Zammad REST API using a token generated directly via the Rails console. Used the API to query open tickets, create tickets programmatically, and build a real-time SLA breach monitoring script.

### API Token creation:

```
sudo zammad run rails r - <<'EOF'
admin = User.find(3)
UserInfo.current_user_id = admin.id
token = Token.create!(
  action: 'api',
  user_id: admin.id,
  name: 'api-monitoring',
  preferences: { 'permission' => ['ticket.agent', 'admin.ticket'] }
)
puts token.token
EOF
```

### Ticket creation via API:

```
curl -s -X POST \
  -H "Authorization: Token token=$TOKEN" \
  -H "Content-Type: application/json" \
  -d @/tmp/ticket.json \
  "http://localhost:3000/api/v1/tickets"
```

### SLA Breach Monitor output (zammad-monitor.sh):

```
=====
Zammad SLA Monitor - Sat May 02 2026
=====
=== OPEN TICKETS WITH SLA BREACH ===
  ☐ OK (57h 27m left) | #13008 | critical database error on production
  ☐ OK (55h 27m left) | #13014 | VPN not connecting from home office
  ☐ OK (54h 27m left) | #13016 | I cannot login to my account
Total breached: 0
=====
```

The monitoring script runs automatically every hour via cron:

```
0 * * * * /home/vml/zammad-monitor.sh >> /var/log/zammad-sla-monitor.log 2>&1
```

---

## Phase 5 — Security Hardening & Backup

### TLS Encryption

Enabled TLS on Postfix using the system snakeoil certificate. Verified Dovecot TLS on port 993 using `openssl`

`s_client:`

```
openssl s_client -connect localhost:993 -quiet
# Result: CN=ubuntu.fritz.box - TLS handshake successful
```

Postfix TLS configuration:

```
smtpd_tls_cert_file = /etc/ssl/certs/ssl-cert-snakeoil.pem
smtpd_tls_key_file  = /etc/ssl/private/ssl-cert-snakeoil.key
smtpd_use_tls       = yes
smtpd_tls_security_level = may
smtpd_tls_protocols = !SSLv2, !SSLv3, !TLSv1, !TLSv1.1
```

### Fail2ban — Brute Force Protection

Four active jails protecting all critical services:

```
❑ dovecot      - IMAP brute force protection
❑ postfix      - SMTP flood protection
❑ postfix-sasl - SMTP auth brute force protection
❑ sshd         - SSH brute force protection
```

Policy: 5 failed attempts within 10 minutes → 1-hour IP ban.

### DSGVO-Compliant Backup

Daily automated backup runs at 02:00 via cron, covering the PostgreSQL database, Zammad file storage, and mail server configuration. Backups are retained for 30 days then automatically purged in compliance with DSGVO data minimisation principles.

### Data Retention Policy

A weekly retention script closes tickets older than 90 days every Sunday at 03:00, ensuring personal data is not held longer than operationally necessary under **DSGVO Article 5(1)(e)**.

---

## Live IT Administration



After completing the full setup, the system was operated as a **Senior IT Administrator** running live daily operations for TechCorp Berlin.

## Daily Morning Routine

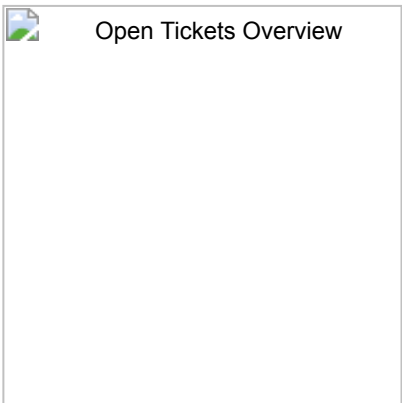
Every operational day begins with a system health check before touching any tickets:

```
sudo /usr/local/bin/morning-check.sh
```

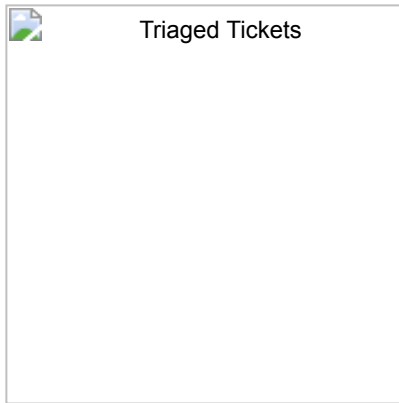
```
=====
TechCorp Berlin - Morning System Check
Sat May 02 06:57:34 AM EDT 2026
=====
--- Zammad Status ---      Active: active (running)
--- Postfix Status ---     Active: active (exited)
--- Dovecot Status ---     Active: active (running)
--- Fail2ban Status ---    Jail list: dovecot, postfix, postfix-sasl, sshd
--- Disk Usage ---         /dev/sda3  59G  17G  39G  30%
--- Open Tickets ---
    L1-Helpdesk:    3 open tickets
    L2-IT-Support:  2 open tickets
    L3-Sysadmin:    2 open tickets
=====
```

## Monday Morning Ticket Triage

On a typical Monday morning, the queue had accumulated 7 tickets requiring immediate triage and assignment. Priority was always assessed by business impact before any investigation began.



Monday morning ticket queue — 7 tickets across L1/L2/L3 requiring triage

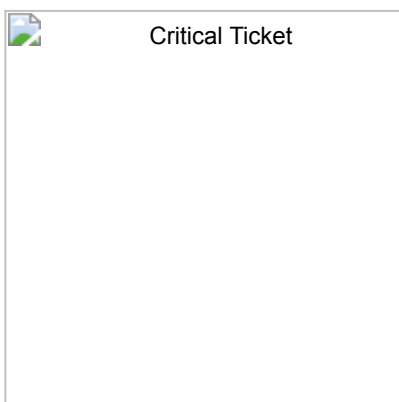


Post-triage overview — all 7 tickets assigned to correct agents across L1/L2/L3

| Ticket                             | Tier  | Assigned To | Priority | Rationale                         |
|------------------------------------|-------|-------------|----------|-----------------------------------|
| CRITICAL - Database backup failed  | L3    | Clara Weber | High     | Data loss risk — immediate action |
| VPN dropping every 30 minutes      | L2→L3 | Clara Weber | High     | 12 users affected — escalated     |
| Exchange server latency            | L2    | Ben Schmidt | High     | Business-wide mail delay          |
| Cannot access Outlook              | L1    | Anna Müller | Normal   | Standard password reset           |
| Printer on 2nd floor offline       | L1    | Anna Müller | Normal   | Localised hardware issue          |
| New laptop setup - Maria Schneider | L1    | Anna Müller | Low      | Planned, non-urgent               |
| Storage server at 89% capacity     | L3    | Clara Weber | Normal   | 8 days before critical            |

## Critical Incident — Database Backup Failure

The highest priority ticket was a failed database backup from Friday night, leaving production data unprotected over the entire weekend.



CRITICAL ticket — database backup failure assigned to L3-Sysadmin

Actions taken immediately:

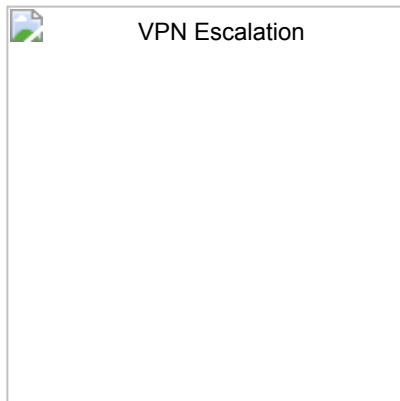
- Assigned to **Clara Weber (L3-Sysadmin)** as infrastructure owner
- Priority escalated to **High**

- Internal note added with 30-minute response commitment
- SLA countdown confirmed active

Investigating failed backup job. Checking cron logs and storage availability. Will report back within 30 minutes. Priority: CRITICAL.  
— Miracle Foka, Senior IT Admin

## Escalation — VPN Issue L2 → L3

After L2 investigation revealed a suspected hardware fault on the core network switch, the ticket was formally escalated to L3 with full documentation of findings.



*VPN ticket showing complete L2→L3 escalation trail with technical findings documented*

Escalation note documented:

- VPN config rollback attempted — issue persisted
- Packet loss detected on core router interface `eth0`
- Suspected hardware fault on switch `SW-CORE-01`
- SLA breach risk flagged — 4 hours remaining on first response SLA

This demonstrates **ITIL functional escalation** based on technical scope, not just time-based SLA breach.

## Ticket Resolution — Full Lifecycle

The Outlook password ticket was resolved within 15 minutes following standard identity verification and AD password reset procedure:



### Resolved Ticket

*Fully resolved ticket showing complete audit trail from creation to closure*

RESOLVED - Password Reset Complete

#### Actions taken:

1. Verified user identity via employee ID (EMP-2024-0892)
2. Reset password in Active Directory
3. Enforced password change on next login
4. Confirmed user can now access Outlook successfully
5. Reminded user of TechCorp password policy:
  - Minimum 12 characters
  - Uppercase, lowercase, number, and special character required
  - Password expires every 90 days

Resolution time: 15 minutes

- Miracle Foka, Senior IT Admin

## Dashboard & Monitoring

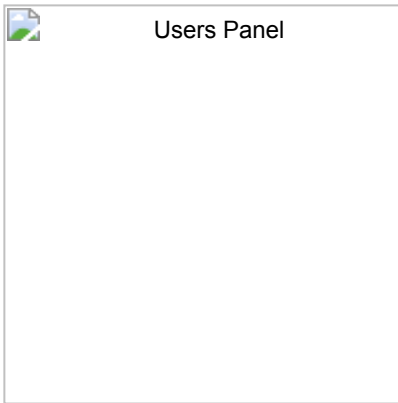


### Dashboard

*Live Zammad dashboard showing real-time activity stream, channel distribution, and operational metrics*

All admin actions (FM) are logged in the Activity Stream with timestamps, providing a complete audit trail.

## Team & Access Management



Full user management panel — agents, supervisors, security analysts, and team leads

The platform uses role-based access control with custom roles beyond standard Agent/Admin: **IT-Supervisor**, **Security-Analyst**, and **Team-Lead**, reflecting real German IT department hierarchy.

# IT Governance, Risk & Compliance

## IT Governance Framework (ITIL v4)

| Principle                                 | Implementation                                                                                                  |
|-------------------------------------------|-----------------------------------------------------------------------------------------------------------------|
| <b>Focus on value</b>                     | Each ticket tier mapped to business impact — VPN outages affecting 12 users prioritised over single-user issues |
| <b>Start where you are</b>                | Existing Ubuntu infrastructure assessed before adding new services                                              |
| <b>Progress iteratively</b>               | Lab built in 5 structured phases, each validated before proceeding                                              |
| <b>Collaborate and promote visibility</b> | All ticket actions, escalations, and resolutions documented — full audit trail maintained                       |
| <b>Think and work holistically</b>        | Mail stack, ticketing, security, and automation treated as one integrated system                                |
| <b>Keep it simple</b>                     | Triggers use clear keyword-based routing; scripts are readable and commented                                    |
| <b>Optimise and automate</b>              | SLA monitoring, backup, retention, and ticket routing fully automated                                           |

## Risk Register

| Risk ID | Description                  | Likelihood | Impact   | Level                             | Mitigation                                  |
|---------|------------------------------|------------|----------|-----------------------------------|---------------------------------------------|
| R-01    | IMAP brute force attack      | High       | High     | <input type="checkbox"/> Critical | Fail2ban — 5 attempts = 1hr ban             |
| R-02    | Email intercepted in transit | Medium     | High     | <input type="checkbox"/> High     | TLS on Postfix + Dovecot                    |
| R-03    | Production database loss     | Low        | Critical | <input type="checkbox"/> Critical | Daily automated backup                      |
| R-04    | SLA breach                   | Medium     | Medium   | <input type="checkbox"/> Medium   | Hourly SLA monitoring + escalation triggers |

| Risk ID | Description                                        | Likelihood | Impact   | Level                             | Mitigation                                                    |
|---------|----------------------------------------------------|------------|----------|-----------------------------------|---------------------------------------------------------------|
| R-05    | Disk exhaustion                                    | Medium     | High     | <input type="checkbox"/> High     | Daily disk check + storage ticket at 89%                      |
| R-06    | Unauthorised ticket access                         | Low        | Medium   | <input type="checkbox"/> Medium   | Role-based access control                                     |
| R-07    | Personal data retained beyond legal limit          | Low        | High     | <input type="checkbox"/> High     | 90-day auto-close, 30-day backup purge                        |
| R-08    | Single point of failure — all services on one host | High       | Critical | <input type="checkbox"/> Critical | Accepted lab limitation; production would use separated hosts |
| R-09    | Weak credentials on mail accounts                  | Medium     | High     | <input type="checkbox"/> High     | Strong password policy in Dovecot passwd file                 |
| R-10    | Undetected service outage                          | Medium     | High     | <input type="checkbox"/> High     | Morning health check monitors all services daily              |

## DSGVO / GDPR Compliance

| Article                                    | Requirement                                | Implementation                                                  |
|--------------------------------------------|--------------------------------------------|-----------------------------------------------------------------|
| Art. 5(1)(e) — Storage limitation          | Data not kept longer than necessary        | Tickets auto-closed after 90 days; backups purged after 30 days |
| Art. 5(1)(f) — Integrity & confidentiality | Data protected against unauthorised access | TLS on all mail transport; Fail2ban blocking brute force        |
| Art. 32 — Security of processing           | Appropriate technical measures             | TLS, Fail2ban, RBAC, encrypted backup                           |
| Art. 25 — Data protection by design        | Privacy built in from the start            | Minimal data collected; auto-close removes stale personal data  |
| Art. 5(2) — Accountability                 | All actions logged and attributable        | Full Zammad Activity Stream; all actions attributed to user ID  |

## BSI Grundschutz Compliance

| BSI Module                   | Control                      | Implementation                                           |
|------------------------------|------------------------------|----------------------------------------------------------|
| APP.5.3 — Postfix            | Secure SMTP configuration    | TLS enforced, weak protocols disabled                    |
| APP.5.3 — Dovecot            | Secure IMAP configuration    | TLS on port 993, passwd-file authentication              |
| OPS.1.1.3 — Patch management | Systems kept up to date      | Ubuntu 22.04 LTS with automatic security updates         |
| OPS.1.1.5 — Data backup      | Regular automated backups    | Daily backup: DB, files, and mail config                 |
| DER.2.1 — Incident handling  | Structured incident response | L1/L2/L3 escalation path with documented procedures      |
| ORP.4 — Identity management  | Role-based access control    | Agent, Admin, IT-Supervisor, Security-Analyst, Team-Lead |

## ITIL v4 Compliance

## ITIL Practice

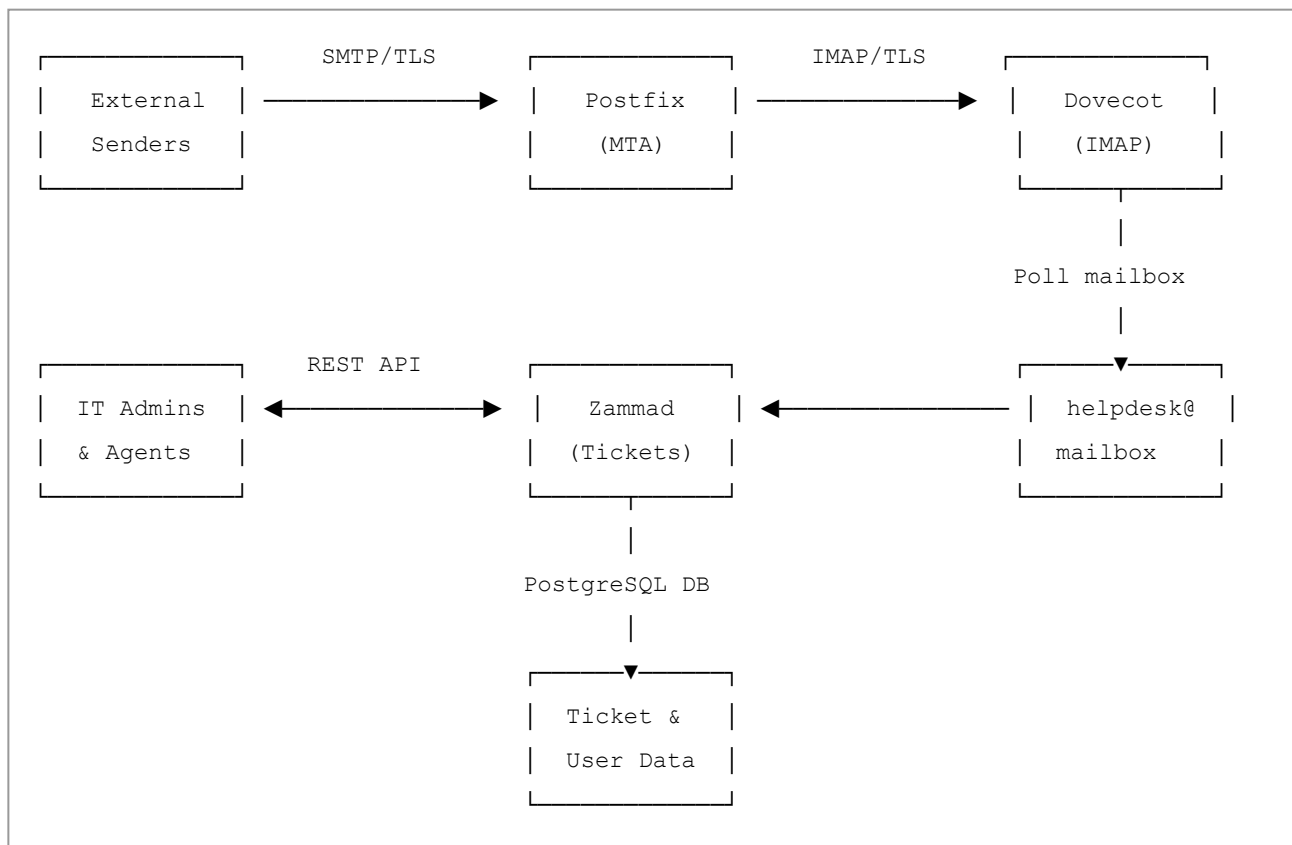
## Implementation

|                          |                                                                                |
|--------------------------|--------------------------------------------------------------------------------|
| Incident Management      | Three-tier routing with SLA enforcement and formal escalation                  |
| Problem Management       | Root cause documented in ticket notes                                          |
| Change Management        | All configuration changes tested and documented before deployment              |
| Service Level Management | Three SLA tiers with automated monitoring and breach alerting                  |
| Service Desk             | Zammad as single point of contact for all IT requests                          |
| Continual Improvement    | Monitoring scripts feed into daily review; retention policy reviewed quarterly |

---

# Threat Modelling — STRIDE + LINDDUN

## System Data Flow Diagram



### Trust Boundaries identified:

- External internet → Postfix (SMTP boundary)
  - Postfix → Dovecot (internal mail boundary)
  - Dovecot → Zammad (IMAP polling boundary)
  - Zammad → PostgreSQL (application-database boundary)
  - Admin browser → Zammad REST API (authentication boundary)
-

# STRIDE Analysis

## Postfix

| Threat                        | Category        | Mitigation                                                          | Status      |
|-------------------------------|-----------------|---------------------------------------------------------------------|-------------|
| Email sender spoofing         | Spoofing        | SPF/DKIM recommended for production; TLS verifies transport         | △ Partial   |
| Mail queue tampering          | Tampering       | Queue files owned by root; restricted filesystem permissions        | □ Mitigated |
| No mail delivery logging      | Repudiation     | <code>/var/log/mail.log</code> records all SMTP transactions        | □ Mitigated |
| Plaintext SMTP interception   | Info Disclosure | TLS enforced; weak protocols disabled                               | □ Mitigated |
| SMTP flood / open relay abuse | DoS             | Postfix relay restrictions; Fail2ban <code>postfix</code> jail      | □ Mitigated |
| Postfix running as root       | Elevation       | Drops privileges to <code>postfix</code> user after binding port 25 | □ Mitigated |

## Dovecot

| Threat                              | Category        | Mitigation                                                            | Status      |
|-------------------------------------|-----------------|-----------------------------------------------------------------------|-------------|
| Credential brute force              | Spoofing        | Fail2ban <code>dovecot</code> jail — 5 attempts = 1hr ban             | □ Mitigated |
| Mailbox file tampering              | Tampering       | Files owned by <code>vmail</code> user; restricted access             | □ Mitigated |
| Failed login attempts not logged    | Repudiation     | Auth failures logged to <code>/var/log/mail.log</code>                | □ Mitigated |
| IMAP credentials in cleartext       | Info Disclosure | TLS enforced on port 993; verified with <code>openssl s_client</code> | □ Mitigated |
| IMAP service crash                  | DoS             | Systemd auto-restart; monitored via <code>morning-check.sh</code>     | □ Mitigated |
| Misconfiguration allowing any login | Elevation       | System auth explicitly disabled; passwd-file auth only                | □ Mitigated |

## Zammad

| Threat                                | Category        | Mitigation                                               | Status      |
|---------------------------------------|-----------------|----------------------------------------------------------|-------------|
| API token theft                       | Spoofing        | Tokens scoped to minimum permissions; stored server-side | □ Mitigated |
| Ticket manipulation via API           | Tampering       | Token auth required for all writes; 403 on unauthorised  | □ Mitigated |
| Admin actions not attributed          | Repudiation     | Full audit trail in Activity Stream                      | □ Mitigated |
| Unauthenticated data access           | Info Disclosure | All endpoints require token; confirmed 401 without token | □ Mitigated |
| Ticket flood causing outage           | DoS             | Rate limited by Postfix; manual review possible          | △ Partial   |
| Agent accessing other groups' tickets | Elevation       | Group-based RBAC — agents only see their assigned groups | □ Mitigated |



## PostgreSQL

| Threat                            | Category        | Mitigation                                                     | Status                             |
|-----------------------------------|-----------------|----------------------------------------------------------------|------------------------------------|
| Connection spoofing               | Spoofing        | DB listens only on localhost; no external access               | <input type="checkbox"/> Mitigated |
| SQL injection via ticket fields   | Tampering       | Zammad uses ActiveRecord ORM with parameterised queries        | <input type="checkbox"/> Mitigated |
| No DB query logging               | Repudiation     | PostgreSQL logging enabled                                     | <input type="checkbox"/> Mitigated |
| Database dump accessible          | Info Disclosure | Backup files owned by root; stored with restricted permissions | <input type="checkbox"/> Mitigated |
| DB crash due to disk full         | DoS             | Daily disk check in <code>morning-check.sh</code>              | <input type="checkbox"/> Mitigated |
| DB user with excessive privileges | Elevation       | Zammad DB user scoped to <code>zammad</code> database only     | <input type="checkbox"/> Mitigated |

## LINDDUN Privacy Analysis

Personal data in scope: ticket records, mail messages, user accounts, backup files, and log files (names, emails, employee IDs, IP addresses).

| Threat ID | Category        | Description                                                | Impact   | Status                                                                        |
|-----------|-----------------|------------------------------------------------------------|----------|-------------------------------------------------------------------------------|
| L-01      | Linkability     | Tickets across incidents can build a behavioural profile   | Medium   | <input type="checkbox"/> Data minimisation applied                            |
| L-02      | Linkability     | Mail logs link IPs to email addresses                      | Medium   | <input type="checkbox"/> Logs not retained beyond operational necessity       |
| I-01      | Identifiability | Employee IDs in ticket notes directly identify individuals | High     | <input type="checkbox"/> Used for verification only; not in searchable fields |
| I-02      | Identifiability | Agent names visible in audit logs                          | Low      | Accepted — necessary for accountability                                       |
| N-01      | Non-repudiation | All admin actions logged — admins cannot deny actions      | Low      | Accepted — satisfies DSGVO Art. 5(2)                                          |
| D-01      | Detectability   | Network observer can detect ticket creation patterns       | Low      | TLS encrypts content; metadata unavoidable                                    |
| DD-01     | Disclosure      | Backup files contain full personal data                    | Critical | <input type="checkbox"/> Encrypt at rest — recommended for production         |
| DD-02     | Disclosure      | API returns full user objects including email              | High     | <input type="checkbox"/> Tokens scoped; HTTPS recommended for production      |
| U-01      | Unawareness     | Customers may not know retention period or access rights   | High     | <input type="checkbox"/> Privacy notice required for production               |
| U-02      | Unawareness     | Auto-created accounts — users may be unaware               | Medium   | <input type="checkbox"/> Explicit consent needed in production                |

| Threat ID | Category       | Description                                                | Impact   | Status                                                      |
|-----------|----------------|------------------------------------------------------------|----------|-------------------------------------------------------------|
| NC-01     | Non-compliance | Retaining tickets indefinitely violates DSGVO Art. 5(1)(e) | Critical | ❑ 90-day auto-close + 30-day backup purge                   |
| NC-02     | Non-compliance | No documented lawful basis for processing                  | High     | ⚠ Art. 6(1)(f) legitimate interest to be documented in RoPA |

## Threat Model Summary

| Framework    | Threats Identified | Fully Mitigated | Partially Mitigated | Accepted/Deferred |
|--------------|--------------------|-----------------|---------------------|-------------------|
| STRIDE       | 24                 | 20              | 3                   | 1                 |
| LINDDUN      | 13                 | 5               | 4                   | 4                 |
| <b>Total</b> | <b>37</b>          | <b>25 (68%)</b> | <b>7 (19%)</b>      | <b>5 (13%)</b>    |

Partially mitigated and deferred items are documented as production recommendations, representing the gap between a homelab and a fully hardened production deployment.

# Cyber Resilience

## Anticipate — Proactive Threat Awareness

- **Daily morning health check** — full service status sweep before tickets are touched
- **Hourly SLA monitoring** — `zammad-monitor.sh` queries the REST API for breaching tickets
- **Fail2ban real-time detection** — brute force attempts blocked automatically without manual intervention
- **Threat modelling (STRIDE + LINDDUN)** — applied proactively during design; 37 threats identified before go-live

## Withstand — Absorbing Disruption

- **Service isolation** — each component runs as an independent systemd service; a crash in one does not bring down the others
- **Tiered support structure** — if L2 is unavailable, L1 continues first-contact handling; critical tickets bypass the queue directly to L3
- **SLA escalation triggers** — tickets self-escalate and notify the responsible agent automatically on SLA breach
- **Fail2ban auto-banning** — active brute force attacks absorbed and neutralised in real time

## Recover — Rapid Return to Normal

### Recovery Objectives:

| Objective                     | Target       | Basis                                               |
|-------------------------------|--------------|-----------------------------------------------------|
| RTO (Recovery Time Objective) | < 30 minutes | Based on backup size (~6MB) and restoration testing |

| Objective                      | Target     | Basis                                            |
|--------------------------------|------------|--------------------------------------------------|
| RPO (Recovery Point Objective) | < 24 hours | Daily backup at 02:00; maximum one day data loss |

#### Database restore:

```
gunzip -c /var/backups/zammad/zammad-db-YYYY-MM-DD.sql.gz | psql zammad
```

#### Mail config restore:

```
tar -xzf /var/backups/zammad/mail-config-YYYY-MM-DD.tar.gz -C /
```

## Adapt — Learning After Incidents

- **Post-incident review** — every ticket is a permanent record; full history preserved for review
- **DSGVO retention as operational learning** — 90-day window allows pattern identification before purge
- **Trigger and SLA tuning** — configurations updated based on observed routing behaviour
- **Formal improvement backlog** tracked and prioritised

#### Improvement Backlog:

| Item                                             | Priority                          |
|--------------------------------------------------|-----------------------------------|
| Encrypt backup files at rest                     | <input type="checkbox"/> Critical |
| Enable HTTPS on Zammad                           | <input type="checkbox"/> Critical |
| Publish DSGVO privacy notice                     | <input type="checkbox"/> High     |
| Document RoPA (Records of Processing Activities) | <input type="checkbox"/> High     |
| Implement SPF/DKIM for email authentication      | <input type="checkbox"/> High     |
| Separate services onto dedicated hosts           | <input type="checkbox"/> Medium   |
| Implement offsite backup replication             | <input type="checkbox"/> Medium   |
| Add MFA for Zammad admin accounts                | <input type="checkbox"/> Medium   |

## NIST CSF Maturity Assessment

| CSF Function    | Capability                                                                     | Maturity                         |
|-----------------|--------------------------------------------------------------------------------|----------------------------------|
| <b>Identify</b> | Asset inventory, STRIDE + LINDDUN threat modelling, 10-risk register           | <input type="checkbox"/> Managed |
| <b>Protect</b>  | TLS on SMTP/IMAP, Fail2ban, RBAC, DSGVO data minimisation                      | <input type="checkbox"/> Managed |
| <b>Detect</b>   | Morning health check, hourly SLA monitor, Fail2ban + application logs          | <input type="checkbox"/> Defined |
| <b>Respond</b>  | L1/L2/L3 escalation paths, automated SLA triggers, full incident documentation | <input type="checkbox"/> Managed |
| <b>Recover</b>  | Daily automated backup, documented restore procedure, RTO < 30min              | <input type="checkbox"/> Defined |

**Overall Posture: Managed.** Primary gap to *Optimised* is the absence of automated service-failure alerting and offsite backup replication — both in the improvement backlog.

# How to Reproduce This Lab

## Prerequisites

- Ubuntu 22.04 LTS (VM or bare metal)
- Minimum 4GB RAM, 40GB disk
- Static internal IP

## Quick Start

```
# 1. Install Zammad
wget -O /tmp/zammad_install.sh https://dl.zammad.org/install.sh
bash /tmp/zammad_install.sh

# 2. Install Postfix + Dovecot
sudo apt install postfix dovecot-imapd dovecot-pop3d -y

# 3. Configure virtual mailboxes
sudo postconf -e "virtual_mailbox_domains = techcorp-berlin.de"
sudo postconf -e "virtual_mailbox_base = /var/mail/vhosts"

# 4. Follow Phase 1-5 documentation above
```

## Scripts Reference

| Script              | Location        | Schedule                   | Purpose               |
|---------------------|-----------------|----------------------------|-----------------------|
| morning-check.sh    | /usr/local/bin/ | Daily (manual)             | System health check   |
| zammad-monitor.sh   | /home/vml/      | Every hour (cron)          | SLA breach monitoring |
| zammad-backup.sh    | /usr/local/bin/ | Daily 02:00 (cron)         | Full system backup    |
| zammad-retention.sh | /usr/local/bin/ | Weekly Sunday 03:00 (cron) | DSGVO data retention  |

# German Enterprise Context

This lab is specifically designed to reflect real workflows in German organisations:

- **DSGVO (GDPR)** — 30-day backup retention, 90-day ticket retention, data minimisation by design
  - **ITIL v4** — Three-tier support structure, formal SLA management, documented escalation process
  - **BSI Grundschutz** — TLS enforcement, brute force protection, role-based access control
  - **Realistic org structure** — L1/L2/L3 tiers with German naming conventions
  - **Domain** — `techcorp-berlin.de` reflecting an authentic German company setup
- 

# License

MIT — Free to use for learning, portfolio, or adapting for real deployments.

---

# Author

**Miracle Foka**

GitHub: [github.com/Miracle-lead](https://github.com/Miracle-lead) (<https://github.com/Miracle-lead>)

*Built as a portfolio demonstration of real-world IT/Sysadmin skills for German enterprise environments.*